openSecureKey

Stand 27.10.2026. Dieser Plan ist am 27.10. vollständig neu geschrieben worden. Die gewachsene Fassung hatte 2071 Zeilen und sagte an zehn Stellen Widersprüchliches — der Akku war viermal verschieden beschrieben, der Massenspeicher dreimal, der Schlüsselexport dreimal. **Was hier steht, gilt.** Jede Entscheidung steht genau einmal; was offen ist, steht als offen.

Einordnung vorweg: Nichts von diesem Gerät ist je auf Hardware gelaufen. Rund 12 000 Zeilen C sind geschrieben und übersetzt, Schaltplan und Platine sind gezeichnet. Die Teile für den Teststand sind bestellt. **Das Projekt steht auf Stufe 2 von 4** — geschrieben / übersetzt / im Abbild / am Gerät gelaufen.

Was am 29.10.2026 selbst nachgemessen wurde, nicht aus Meldungen übernommen: sechs Prüfläufe der Stränge, jeder einzeln gestartet — `se050` 1066, `authz` 255, `ctap` 1425, `store` 87 591, `transport` 232, `applets` 1384 Fälle, **zusammen 91 953, kein Fehler**. Dazu `tools/check.py`: 14 Schritte ok, 308 Tests, 0 Fehler. **Drei Schritte sind dort übersprungen und damit NICHT geprüft:** `firmware/build` (kein nRF Connect SDK), `firmware/tests` und `firmware/format`. Die C-Prüfläufe der Stränge laufen deshalb ausdrücklich nicht über `check.py`, sondern über die Skripte in `apps/firmware/test/*/` — „check.py ist grün" sagt über die Firmware nichts.

---

1. Was das Gerät ist

Ein USB-Sicherheitsschlüssel, der zusammenbringt, was es sonst nur einzeln gibt: **FIDO2/Passkeys**, **Smartcard** mit eigenen Zertifikaten, **Einmalcodes** und einen **echten Passwortspeicher**. Dazu eine **Krypto-Geldbörse**, eine **Dongle-Funktion** für eigene Software und einen **verschlüsselten Datenträger**, den man weitergeben kann.

Alles selbst: Schaltplan, Platine, Firmware, Verwaltungsprogramm. Fremdcode wird nicht eingebunden; Hersteller-SDKs bleiben Werkzeug.

Was kein Mitbewerber hat: Passwortspeicher (768 Einträge je Profil, 3072 im Gerät — OnlyKey schafft 24, Nitrokey Pro 16, Yubico hat keinen), **Anzeige am Gerät** (Grundlage dafür, dem Rechner nicht glauben zu müssen), Geldbörse mit Betragsanzeige, Dongle-Betrieb, und ein Datenträger zum Weitergeben.

---

2. Hardware

Teil	Wahl	Anmerkung
Rechenkern	nRF52840 als Funkmodul **Raytac MDBT50Q-1MV2**	vorzertifiziert — sonst müsste die Platine selbst als Funkgerät geprüft werden
Sicherheitschip	**SE051C2** — gezeichnet, bestellt, und es bleibt dabei	Prüfbar nach Lieferung an der Kennung: **A8FA** oder **A564** = richtig, **A920** oder **A565** = falsche Variante, dann fehlen RSA und alle Edwards-Kurven
Flash	W25Q512JVEIQ, 64 MB (QSPI)	Tresor, Geräteprotokoll, Programmlaufwerk
Datenträger	**microSD-Schacht**, Push-Push	tauschbar — nur so sind die Betriebsarten 2 und 3 möglich; kostet keine Länge
Anzeige	Crystalfontz CFAL4864A-071BW, 0,71"	kleinster belegter; der nächstgrößere ist breiter als die ganze Platine
USB	GCT **USB4155-03-C** (LCSC C5183853)	Randstecker, für 0,8 mm belegt, Lötbildtiefe **3,303 mm** (gemessen, nicht 2,50 — die Schirmstifte reichen tiefer)
Fingerabdruck	FPC2534, **Bestückungsstufe 2**	Stiftreihe J5 liegt auf der Platine
Energie	**kein Akku**	siehe unten
Platine	**27 × 59,55 mm**, 0,8 mm, 4 Lagen, beidseitig	obere Schranke; mit versetztem Taster wären ~56,55 mm möglich

Kein Akku

Entschieden am 25.10.2026. Keine Zelle, kein Laderegler, keine Schutzschaltung; 14 Bauteile sind aus Schaltplan und Platine entfernt.

- **Die Uhr** wird beim Einstecken vom Rechner gestellt. Einmalcodes entstehen im Moment des Benutzens — und da steckt das Gerät. **Das war der Befund, der den Akku überflüssig machte.**
- **NFC und Bluetooth** gibt es nur am Rechner; der Rechenkern kann sich nicht aus dem NFC-Feld versorgen. Bewusst in Kauf genommen.
- **Gewonnen:** 10,45 mm Länge, kein Verbrauchsteil (ein LiPo im Anhänger hält wenige Jahre), keine Antennendämpfung, kein Laufzeitrisiko.
- **Der Manipulationsschutz braucht ihn nicht.** Epoxid-Verguss ersetzt die Reaktionsschaltung — belegt am iStorage datAshur PRO, einem Stick mit FIPS 140-3 **Overall Level 3 und ohne jede Tamper-Elektronik**.

> **Er käme nur unter drei Bedingungen zurück**, und alle drei werden eingehalten: ein abnehmbarer Deckel, eine Debug-Schnittstelle, oder ein Klartextschlüssel, der in Ruhe im Flash liegt.

Die Grenze, die bleibt: Durchsatz

> **Entscheidung vorweg, damit die Tabelle unten nicht missverstanden wird: Der Rechenkern wird NICHT gewechselt. Der nRF52840 bleibt.** Die Zahlen stehen hier, damit später jemand weiß, was ein Wechsel brächte — nicht, weil einer geplant wäre.

Der Rechenkern schafft am USB **rund 400 kB/s** — Bulk-Endpunkte sind auf 64 Byte je Mikroframe begrenzt (Nordic). Die microSD läuft über SPI mit einer Datenleitung: **rund 3 MB/s**.

	heute, und dabei bleibt es	*hypothetisch, bei nRF54LM20*
1 GB	42 min	*5,6 min*
16 GB	11,1 h	*1,5 h*

Warum nicht gewechselt wird: Ein Wechsel brächte Faktor 7,5 — danach bremst der Speicher, und **kein Chip mit BLE *und* NFC hat einen 4-Bit-Kartenanschluss**. Das in Frage kommende Modul (BL54LM20B) ist Vorserie: Beta-Muster, kein Preis, Zulassungen teils offen. Und der Wechsel hieße neue Platine, neue Längenrechnung, neue Brettdefinition.

Wann die Frage wieder aufgemacht wird: sobald das Modul lieferbar ist. Dann sprechen 512 KB RAM statt 256 und 2 MB Flash statt 1 dafür — und eine Zahl, die heute fehlt, entscheidet mit: **wie schnell AES-256-GCM am Gerät läuft.** Liegt sie unter 3 MB/s, wäre auch nach einem Wechsel nichts gewonnen.

> **Folge fürs Handbuch:** Die 27 MB portabler Programme brauchen beim Lesen rund **68 Sekunden**. „Einstecken, starten" ist einstecken, über eine Minute warten, starten.

---

3. Was das Gerät können muss

Anmelden und Ausweisen

FIDO2/WebAuthn/Passkeys · U2F/CTAP1 · PIV · OpenPGP · TOTP · HOTP · Yubico-OTP · Challenge-Response HMAC-SHA1 · statisches Passwort · hmac-secret/PRF · largeBlob · credProtect · minPinLength · Enterprise Attestation · mTLS · EAP-TLS · Kerberos/PKINIT · SSH mit Zertifikaten · PAM

Wege zu fremder Software

Einen Standard, über den jede App Passwörter aus einem Stick holt, gibt es nicht. Darum alle Wege, die es gibt:

Weg	**erreicht damit**
Gerät tippt als USB-Tastatur	jede Software, auch Anmeldebildschirm und BIOS

Weg	erreicht damit
PKCS#11	Firefox, Thunderbird, OpenSSL, OpenSSH, Java, VPN
Minidriver + CNG (Windows)	jede Windows-App, Windows-Anmeldung
CryptoTokenKit (Mac/iPhone)	Safari, Mail, Keychain
ssh-agent	`ssh`, `git`, Ansible
FIDO-SSH (`sk-ecdsa`)	OpenSSH ohne Zusatzprogramm
Browser-Erweiterung	Chrome, Firefox, Edge
Kommandozeile `osk get`	Skripte, CI, Docker
lokale Schnittstelle	eigene Programme

> **Und wenn eine Software nur Dateien kennt — PEM, PFX, `.key`?** Das ist der häufigste Fall, an dem Hardware-Schlüssel scheitern, und die Antwort hat zwei Hälften: **Das Zertifikat kann das Gerät herausgeben**, als PEM oder DER. Ein Zertifikat ist öffentlich — es weiterzugeben kostet nichts. Für alles, was nur die Bescheinigung braucht (Serverkonfiguration, Vertrauensspeicher, eine Kette zum Mitliefern), genügt das. **Den privaten Schlüssel gibt es nicht als Datei. Nie.** Software, die zwingend eine Schlüsseldatei verlangt — ein `.pem` mit `PRIVATE KEY` darin, ein `.pfx` mit Passwort — **kann dieses Gerät grundsätzlich nicht bedienen.** Das ist kein Mangel, sondern sein Zweck: Was als Datei vorliegt, ist kopierbar. **Der Ausweg ist in fast allen Fällen PKCS#11**: OpenSSL, nginx, Java, VPN-Clients und Signierwerkzeuge nehmen statt eines Dateipfads eine Schlüssel-Adresse (`pkcs11:object=...`) entgegen. Wer das kann, braucht keine Datei. Wer es nicht kann, bleibt außen vor — **und das gehört ins Handbuch**, sonst sucht jemand stundenlang nach einer Exportfunktion, die es absichtlich nicht gibt.

Tresor

Eintragstypen: Login · TOTP · HOTP · SSH-Schlüssel · Zertifikat · PGP-Schlüssel · API-Schlüssel · Wiederherstellungscodes · Wallet-Seed · Lizenz · Karte · Identität · WLAN · Notiz · Datei

4 Profile mit je eigener PIN · 768 Einträge je Profil · AES-256-GCM · Suchmarke ohne Entschlüsseln · stromausfallsicher · Formatwanderung bei Updates · Geräteprotokoll (512 Einträge) · verschlüsselte Sicherungsdatei mit **Shamir-Umschlägen**

Alltag: Passwortgenerator · doppelte, kurze und alte Passwörter finden · Ordner, Etiketten, Suche · Phishing-Schutz (die Erweiterung füllt nur auf der hinterlegten Adresse) · Oberfläche in fünf Sprachen

Geldbörse

Nur Bitcoin und Ethereum. (Frühere Zusagen zu Solana und Cardano sind nirgends umgesetzt und gestrichen.) BIP39/BIP32/BIP44 · PSBT · EIP-155/1559/712 · Ledger-verträgliche APDU-Schicht für MetaMask und Electrum · **Blindsignieren wird verweigert** — was das Gerät nicht lesbar anzeigen kann, signiert es nicht. Taproot wird ausdrücklich abgelehnt: „die Hälfte davon wäre gefährlicher als nichts."

Dongle und Server (NGC)

Challenge-Response gegen das Gerätezertifikat · **Entschlüsselung geschützter Programmteile** (nur die zweite Stufe ist echter Schutz; eine reine Ja/Nein-Abfrage lässt sich herausschneiden) · Bibliothek `osk-guard` für C, Go, PHP, .NET, Python · Knotenschlüssel im Chip statt auf der Platte · Dauerbetriebsmodus für Server, ausdrücklich einzuschalten und protokolliert.

Datenträger — drei Betriebsarten

Die microSD wird **nur in unseren eigenen Sticks** gelesen, nie in einem fremden Kartenleser. Das Format auf der Karte ist deshalb frei wählbar; der Stick zeigt dem Rechner ein gewöhnliches Dateisystem und übersetzt.

	Wer kann lesen	Geheim?
1 — nur dieser Stick	nur der Stick, der beschrieben hat	ja

	Wer kann lesen	Geheim?
2 — mit Kartenwort	jeder openSecureKey, der das Wort kennt	ja
3 — nur gesiegelt	jeder openSecureKey	**nein**

Alle drei haben **Merkle-Baum und Signatur**; der Unterschied liegt nur darin, wie — und ob — der Datenschlüssel eingewickelt ist. Empfängermodell wie `age`: Chipschlüssel, Kartenwort, oder der öffentliche Schlüssel eines anderen Sticks.

> **Die Anzeige muss den Modus nennen, bevor geschrieben wird.** Wer glaubt verschlüsselt zu haben und hat nur gesiegelt, gibt Geheimnisse weg — der schlimmste Fehler, den dieses Gerät machen kann, und er entsteht aus einer Verwechslung, nicht aus einem Angriff.

Zwei Grenzen, die ins Handbuch gehören:

1. **Echtheit ist nicht Urheberschaft.** Die Signatur beweist, dass die Daten unverändert sind. Dass sie von einer bestimmten Person kommen, beweist sie nur, wenn der Empfänger deren öffentlichen Schlüssel vorher kennt.
2. **Geprüft wird beim Lesen, nicht beim Einstecken.** Eine 16-GB-Karte vollständig zu prüfen hieße, sie ganz zu lesen — **1,5 Stunden**. Der Merkle-Baum prüft je Block nur dessen Pfad. Ein veränderter Block in einer Datei, die niemand öffnet, bleibt unentdeckt. „Karte geprüft" wäre eine Lüge, „dieser Block geprüft" die Wahrheit.

Verschlüsseln, signieren, Zertifikate

- **Dateien:** `age` **und** OpenPGP-Nachrichten, mit Blockverfahren. `age` passt gut — X25519 und ChaCha20-Poly1305 haben wir, es hat eine Erweiterungsschnittstelle für Hardware-Schlüssel und seit 2025 post-quanten-hybride Empfänger.
- **Ordner und Linux-Laufwerke fallen uns zu:** `gocryptfs` (`-fido2`) und LUKS2 (`systemd-cryptenroll`) brauchen nur **hmac-secret**, und das ist fertig. Kein eigenes Container-Format bauen. BitLocker nutzt denselben Mechanismus — belegt ist das für Windows aber nicht, also messen statt behaupten.
- **Zertifikate: CSR nach PKCS#10 auf dem Gerät** — die Grundfunktion, ohne die kein Zertifikat zu einem Chip-Schlüssel entsteht. Dazu Kette, X.509-Erweiterungen (SAN, Key Usage, EKU), **Widerrufsweg (CRL oder OCSP)** und Ablaufwarnung. **Eine CA ohne Widerruf wird nicht gebaut.**
- **Signaturen:** `sshsig`, Git-Commit-Signatur, **RFC-3161-Zeitstempel**.

Vorsorge

- **Stick zu Stick** über USB — der Hauptweg bei Verlust. Beide zeigen dieselbe Zahl, beide bestätigen mit Tastendruck.
- **CXF** (FIDO Credential Exchange Format, Standard seit 8/2025) für Import *und* Export von Passkeys, Passwörtern, TOTP und SSH-Schlüsseln. Schlägt zwei Lücken auf einmal: der Weg hinein aus fremden Managern und der Weg hinaus.
- **Verschlüsselte Sicherungsdatei** mit Shamir-Umschlägen für Familie oder Notar.
- **Importwege** aus KeePass, CSV und Browsern; Leak-Prüfung über k-Anonymität.
- Dienste-Liste je Stick, Sperrvermerk bei Verlust.

> **Spannung, die ins Bedrohungsmodell gehört:** Export heißt, dass Zugangsdaten das Gerät verlassen können. Das widerspricht „Schlüssel verlassen den Chip nie" — für Passkeys ist es mit dem Modus „gespiegelt" ohnehin entschieden. CXF macht es nur sichtbar und verlangt dieselbe Freigabe: PIN, Tastendruck, und eine Anzeige, die sagt **wohin**.

---

4. Sicherheit

Warum ein zweiter Chip: Die Auslesesperre des nRF52840 wurde schon durch Spannungs-Störimpulse überwunden. Darum liegt **kein Geheimnis dauerhaft im Rechenkern**.

- Schlüssel entstehen im Sicherheitschip und verlassen ihn nie
- Leitung dorthin verschlüsselt (SCP03) — **die Werksschlüssel sind öffentlich bekannt, der Austausch beim ersten Start ist Pflicht und fehlt heute**
- Fehlversuchszähler im Chip, nicht im Flash
- Jede Herausgabe: PIN (je Sitzung) **und** Tastendruck (je Vorgang)
- **Automatisches Sperren** nach Zeit, **sofortiges Sperren beim Abziehen**
- Besonders geheime Einträge nur an **gekoppelten Rechnern**; dazu ein schreibgeschützter **Gastmodus**, in dem nichts geändert werden kann
- Das Programm zeigt immer, **welche Software gerade fragt**
- **Zurücksetzen auf Werkszustand** nur mit langem Tastendruck und getippter Bestätigung; **Selbstlöschung nach n Fehlversuchen**, abschaltbar
- Vergleiche mit gleicher Laufzeit, Zufallsverzögerung — **genau diese Fehlerklasse hat 2024 den Marktführer getroffen**: EUCLEAK, jeder YubiKey 5 vor Firmware 5.7 war klonbar (Infineon SLE78, nicht-zeitkonstante Inversion)
- RAM nach jedem Vorgang gelöscht, kein dynamischer Speicher in Krypto-Pfaden
- Parser für APDU, CTAP und NDEF werden gefuzzt
- Kein Server, keine Wolke, keine Telemetrie

Post-Quanten

NIST-Standards seit 8/2024. Kein Hardware-Schlüssel am Markt hat sie, und der Sicherheitschip kann sie nicht.

Entschieden: hybrid. ML-KEM **zusammen mit** X25519, gerechnet im Rechenkern (55 ms, ~11 kB Flash). Betroffen: Stick-zu-Stick, Server-zu-Server, CXP-Export. **Nicht betroffen:** die Sicherungsdatei — sie ist symmetrisch, AES-256 gilt als quantensicher.

> **Regel: hybrid oder gar nicht.** Fällt der PQC-Teil, bleibt X25519 aus dem Chip und nichts ist schlechter als heute. Ein reiner PQC-Pfad wäre ein Rückschritt, weil der Schlüssel dann nicht im Chip läge.

FIPS 140-3 Level 3

Arbeitsregel von Thomas, gilt dauerhaft und für alle Projekte: Wird ein Standard genannt, werden seine **technischen Anforderungen gebaut**. Nur der bezahlte Prüflauf wird geschoben — und es wird nichts getan, was ihn später verbaut.

Drei Punkte betreffen die Platine sofort:

1. **Epoxid-Verguss** über allen sicherheitsrelevanten Bauteilen — er ersetzt die Tamper-Schaltung. Platz, Höhe, Wärmeabfuhr und ein Fertigungsschritt gehören eingeplant; Prüfpunkte müssen danach unerreichbar sein. **Später nicht nachrüstbar.**
2. **Kein abnehmbarer Deckel.**
3. **Keine Debug-Schnittstelle** — allein ihre Existenz löst die Pflicht zur Reaktionsschaltung aus, und damit käme der Akku zurück.

Für die Firmware:

- **Die PIN darf nie über USB laufen.** Ab Stufe 3 ist ein vertrauenswürdiger Kanal Pflicht — damit wird die **PIN-Eingabe am Gerät** (Anzeige + Taster) von einer guten Idee zur Anforderung. Offen ist nur die Bedienung: eine sechsstellige PIN mit *einem* Taster durchzublättern ist zäh; zwei Taster oder langer/kurzer Druck sind zu prüfen.
- **Nie ein Klartextschlüssel in Ruhe:** PIN → langsame Ableitung → KEK → DEK.
- **Ed25519/X25519 als abschaltbare Nicht-FIPS-Erweiterung.**
- **Ein abgegrenzter, selten geänderter Sicherheitskern.** Zertifizierung und laufende Entwicklung vertragen sich nicht: Jede Firmware-Änderung macht einen Prüflauf ungültig. Das Vorbild erkauft seine Stufe damit, **gar keine Aktualisierung** zuzulassen. Für uns: signierte Firmware mit Prüfung im Gerät, Kern klein halten, Oberfläche

außerhalb.

Level 4 ist als Geräte-Eigenschaft nicht baubar (Erkennungshülle braucht Dauerstrom; mehrfaktorige Authentifizierung ist mit einem Taster nicht erfüllbar). **Als Chip-Eigenschaft ist physische Sicherheit Stufe 4 schon erreicht** — aktives Schirmgitter, ohne eigene Energiequelle.

Zur Einordnung: Der **YubiKey 5 FIPS** erreicht Overall Level 2 mit Physical Security Level 3. Overall Level 3 hat bei Yubico nur das YubiHSM. **Unser Vorbild ist der datAshur PRO** — ein Stick, der Overall Level 3 mit Verguss statt mit Elektronik erreicht.

Ein Gegensatz bleibt und ist nicht auflösbar: Eine FIDO-Zertifizierung verträgt sich nicht mit gespiegelten Passkeys. Entweder ist das Zweitgerät ein echter Ersatz, oder die Bescheinigung ist gerätegebunden.

---

5. Was gebaut wird

Aus dem Marktabgleich gegen Yubico (alle Produkte inkl. YubiHSM 2), Nitrokey, SoloKey und OnlyKey: **achtzehn Punkte, sechs Stränge.**

Die Stränge — je ein Ordner, keine Überschneidung

	Ordner	Aufgaben
A	`se050/`	**RSA** (2048/3072/4096), **monotone Zähler** (AN13187), **SCP03/SCP11 zur Karte** samt Schlüsselaustausch beim ersten Start
B	`ctap/`	**CredentialManagement (0x0A)**, **Config (0x0D)**, **Enterprise Attestation**, **Signaturzähler in den Flash**, **PIN-Regelwerk**
C	`applets/`	**RSA in PIV und OpenPGP**, **statisches Passwort**, **PIV-Attestierung je Steckplatz (F9)**, **eindeutige Seriennummer**
D	`store/`	**Rückdrehschutz** über Chipzähler, **hash-verkettetes Protokoll**, **Abstreitbarkeit**, **Selbstzerstörungs-PIN**, **Kapazitäten**
E	`transport/`	**Yubico-HID-Report-Protokoll**
F	neue Schicht	**16 Rechtebereiche**, **mehrere Zugangsschlüssel**, **YubiHSM Auth**, **RFC-3161-Zeitstempel**

Entschieden: alle sechs gleichzeitig, und die Arbeit läuft weiter, während die bestellten Teile unterwegs sind.

Die Vorarbeit, ohne die alles kollidiert

`include/osk_se050.h` **kennt weder RSA noch Zähler** (gemessen). Beides brauchen mehrere Stränge; dasselbe gilt für den Signaturzähler (gezählt wird in CTAP, gespeichert im Tresor).

Darum zuerst, vom Master allein: die Schnittstellen festlegen — zwei Header, keine Umsetzung. Danach bauen alle Stränge dagegen, auch wenn die Umsetzung dahinter fehlt.

> **Der Nebeneffekt ist mehr wert als die Vorarbeit kostet:** Alle Stränge arbeiten gegen `osk_se050.h` und sehen nicht, was dahinter antwortet. Wird der Sicherheitschip je getauscht, ändert sich eine Schicht — nicht fünf.

Querschnitt, kein eigener Strang

- **Zwei Firmware-Varianten** (mit und ohne RSA) als Kconfig-Option. Folgen: zwei Signaturen, zwei Prüfläufe, **zwei AAGUIDs** (FIDO verlangt, dass ein AAGUID eine Fassung mit denselben Fähigkeiten bezeichnet), und die Variante muss in Dateiname **und** Abbildkopf stehen, sonst spielt jemand die falsche auf.
- **Hybrides ML-KEM** für Stick-zu-Stick, Server-zu-Server und CXP.
- **Dateiwerkzeug** `osk encrypt` / `osk decrypt`.
- **CSR und CA-Verwaltung**, mit Widerrufsweg.
- **CXF-Import und -Export.**

Was nicht gebaut wird — mit Grund

	Warum nicht
Verschlüsselter Massenspeicher (Nitrokey Storage)	**erledigt, unter anderem Namen** — der microSD-Datenträger kann mehr: weitergeben und Echtheit prüfen
Fingerabdruck in Stufe 1	Bestückungsstufe 2. Bei FIDO2 *ersetzt* Biometrie die PIN — sie ist kein zusätzlicher Faktor. `BioEnrollment` bleibt abgelehnt: keine Website darf einen Finger einlernen
Lightning	proprietär, von USB-C abgelöst
FIDO über Bluetooth	Browser unterstützen es nicht verlässlich; BLE dient nur dem eigenen Programm
Eigenes Container-Format	gocryptfs und Cryptomator existieren und brauchen uns nur als Schlüssel
PAdES/CAdES/XAdES	später; die höheren Stufen hängen an der CA
M von N — den Schlüssel in Teile zerlegen	**entschieden am 27.10.2026: nein**, aus drei Gründen. Siehe Kasten
JavaCard als Sicherheitschip	**entschieden: nein.** JCOP-Chips gibt es nicht im Handel — NXP liefert nur Wafer oder Module an Kartenhersteller, über Direktvertrieb. Im Handel sind nur fertige Karten

> **Warum M von N nicht gebaut wird — der wichtigste Verzicht in diesem Plan:** *Die Idee:* Der Schlüssel wird in **N Teile** zerlegt (etwa sieben Umschläge, nicht Geräte), und **irgendwelche M** davon (etwa vier) öffnen ihn wieder. Damit übersteht ein Wurzelzertifikat den Verlust des Geräts, ohne dass ein einzelner Verwalter allein herankommt. **1. Es macht das Gerät angreifbarer, nicht sicherer.** Heute kann ein Schlüssel den Chip **gar nicht** verlassen — wer das Gerät stiehlt und aufbohrt, bekommt nichts. Damit Teile entstehen können, muss der Schlüssel erst heraus. Danach liegt er in sieben Umschlägen in der Welt statt in einem Chip. **2. Es löst ein Problem, das dieses Gerät nicht hat.** Der Verlustfall ist dreifach abgedeckt: Zweitstick über Stick-zu-Stick, verschlüsselte Sicherungsdatei mit Shamir-Umschlägen, und für ein Wurzelzertifikat der klassische Weg — offline erzeugt, auf Papier, im Tresor. Das ist sicherer als jedes Gerät. **3. Die Hardware dafür ist nicht beschaffbar.** Der SE051 kann keinen Schlüsselexport (AN12413), und JavaCard — der einzige Weg dorthin — ist als Chip nicht zu kaufen. **Was bleibt:** das vorhandene Shamir-Verfahren auf dem **Dateischlüssel** der Sicherung (`osk_shamir.c`), etwa 3 von 5. Ein echter Schwellenwert, aber auf einer Datei statt auf dem Chipschlüssel — und genau deshalb ungefährlich.

---

6. Die acht Widersprüche in den eigenen Unterlagen

Vor allem anderen zu klären. Solange die Unterlagen sich widersprechen, ist jede Planung auf Sand gebaut. Die vier schwerwiegenden:

1. **Ist für ARM übersetzt worden?** `docs/build.md` und `architecture.md` sagen ja, mit gemessenen Zahlen (161 124 B). `docs/update.md` und `CHANGELOG.md` sagen nein. **Davon hängt ab, auf welcher Stufe das Projekt steht.**
2. **Ist PIV, OpenPGP, Wallet, Anzeige, Funk geschrieben?** `architecture.md` sagt nein; die vier Einzeldokumente beschreiben alles als geschrieben und getestet, mit Dateilisten.
3. **Wie viele Credentials?** `ctap.md` sagt unbegrenzt (abgeleitet), `architecture.md` sagt endlich (Chipspeicher). Genau die Zahl, die Yubico mit 100 Passkeys beziffert.
4. **Nutzerspeicher: 46, 50 oder 104 kB?** Drei Dokumente, drei Zahlen. *Teilantwort aus AN12973: es ist eine Spanne, 46–104 je nach Konfiguration.*

Und die vier übrigen, damit die Zahl im Titel stimmt:

5. **War die Auslagerung des Update-Platzes nötig?** `architecture.md` und `update.md` begründen ausführlich, warum der zweite MCUboot-Platz ins externe Flash muss — und halten danach fest: „war nicht nötig".
6. **27,5 oder 29,10 MB** für die drei portablen Programme? `hardware.md` rechnet 27,5 (23.10.), `laufwerk.md` misst 29,10 (24.10.). Aus „34,5 MB frei für den Tresor" werden damit 28,2 plus 6,82 MB Reserve.
7. **PKCS#11-Freigaben:** Dieselbe Datei sagt an einer Stelle, ssh-agent und PKCS#11 holten noch jeden Schlüssel einzeln — und zwei Abschnitte höher, das sei am 24.10. geschlossen worden.
8. **Kann der gelieferte Chip Ed25519, X25519 und ECDH?** Die FIPS-Politik eines echten SE051 zeigt die Maske `0x27F2`: EdDSA aus, Curve25519 aus. Die Variantentabelle AN12973 sagt das Gegenteil. **Entschieden**

wird es am gelieferten Teil — Kennung lesen, einmal, und die Frage ist weg.

> **Das Muster dahinter, in diesem Projekt sechsmal aufgetreten: zwei Größen, die gleich heißen und Verschiedenes messen.** Padmitten gegen Kupfer. Kontaktzahl gegen Pinzahl. Gigabit gegen Gigabyte. Luftlinie gegen verlegte Länge. Gehäusetiefe gegen Lötbildtiefe. Zellenmaße mit und ohne Schutzplatine.

---

7. Stufen

Jede Stufe endet mit einer **Messung am Gerät**, nicht mit einem grünen Bau.

	Inhalt	Prüfung
1	Teststand: SDK, Bau, Brett läuft	USB erkannt, Taster/LED
2	**Sicherheitschip lebt**	**Kennung lesen: A8FA/A564 = richtig, A920/A565 = falscher Chip.** Schlüssel erzeugen, signieren, am PC nachrechnen; **am I²C mitlesen — kein Klartext**
3	FIDO2 über USB, **CredentialManagement, Config, Enterprise Attestation, Signaturzähler im Flash, PIN-Regelwerk**	echter Passkey, Chrome und Windows Hello. Dazu: LUKS2 und gocryptfs entsperren
4	NFC	Anmeldung am Handy
5	Smartcard: PIV, OpenPGP, OTP, **RSA**, **Yubico-HID-Transport**, **statisches Passwort**, **PIV-Attestierung**, **CSR**, **Seriennummer**	Zertifikat, E-Mail signieren, SSH, **KeePassXC und VeraCrypt entsperren**
6	Tresor, **Rückdrehschutz**, **verkettetes Protokoll**, **Kapazitäten**	Passwort getippt, TOTP gegen zweite App, **zurückgespielter gültiger Zustand wird erkannt**
7	Verwaltungsprogramm	Windows, dann Linux, dann Mac
8	Anbindungen, **Dateiwerkzeug** (`age`, OpenPGP), **sshsig**, **Git-Signatur**	je eine echte Operation: `git push`, `openssl`, Firefox, Erweiterung
9	Bluetooth	Kopplung mit Zahlenvergleich
10	Eigene Platine, **Verguss**	DRC 0, Gerber nachgemessen
11	Anzeige, **PIN-Eingabe am Gerät**	richtige Webseite am Gerät — und bei untergeschobener Anfrage die falsche, sichtbar
12	Fingerabdruck	Anmeldung allein mit Finger
13	Geldbörse	Testnetz-Überweisung aus Electrum und MetaMask
14	Dongle und Server, **YubiHSM Auth**, **Rechtebereiche**	Programm startet nur mit Stick; NGC signiert einen Auftrag
15	Laufwerk	an fremdem Rechner ohne Adminrechte starten
16	iPhone, dann Android	
17	Alltag und Vorsorge, **CXF**, **Importwege**, **Abstreitbarkeit**, **Wisch-PIN**	Zweitstick, Sicherung, Import aus KeePass
18	Aktualisierung und Herstellung	MCUboot A/B, reproduzierbarer Bau
—	**Eigene CA** (Kette, Widerruf, Ablaufwarnung) · **Datenträger** (drei Betriebsarten) · **ML-KEM** als Querschnitt	eigene Stufen, Einordnung offen

Der signierte Bootloader kommt früh (mit Stufe 3 ins Abbild) — sonst müsste später die Auslesesperre gelöst werden, und das löscht den Chip.

---

8. Prüfung

Vier Stufen von „geprüft": geschrieben / übersetzt / im Abbild / am Gerät gelaufen. Im Protokoll steht, welche.

- Jeder Strang liefert PC-Tests; **keiner meldet mehr als Stufe 2**, bis Hardware da ist.

- Neue Parser werden gefuzzt — das Yubico-HID-Protokoll ist ein Parser, den ein Angreifer unmittelbar erreicht.

Drei Dinge, die sonst durchrutschen:

1. **Der Signaturzähler muss einen Neustart überstehen.** Heute steht er im RAM und fängt bei null an; ein Test, der nur innerhalb eines Laufs zählt, zeigt den Fehler nicht.
2. **Der Rückdrehschutz muss gegen einen zurückgespielten, in sich gültigen Zustand prüfen**, nicht gegen einen verfälschten. Genau das ist der Angriff.
3. **Beide Firmware-Varianten** müssen gebaut und geprüft werden. Eine Option, die nur in einer Richtung getestet ist, ist keine.
4. **Eine Attrappe prüft die eigene Seite des Vertrags, nicht die andere.** Am 29.10.2026 am Signaturzähler aufgetreten: CTAP spricht den geräteweiten Zähler mit der reservierten Kennung 0 an, der Tresor sucht zu jeder Kennung einen Indexsatz und findet für die 0 keinen — am Gerät wäre **gar nicht signiert** worden. Grün war trotzdem alles: die Attrappe in `test/ctap/mocks.c` führt selbst einen geräteweiten Zähler und übergeht die Kennung. **Zwei Größen, die gleich heißen und Verschiedenes messen — das achte Mal in diesem Projekt**, und das erste Mal zwischen zwei Strängen statt in einer Unterlage. **Entschieden am 29.10.2026:** Kennung 0 ist der geräteweite Zähler und liegt als `sigcount_dev` im Kopfsatz (vier Byte aus `reserved[16]`, crc32 bleibt letztes Feld); jede andere Kennung zählt weiter je Eintrag. Das deckt alle Nachweise ab — nicht auffindbare Nachweise und U2F haben keinen Indexsatz, in dem ein Zähler liegen könnte, und das sind die meisten. Offen daraus: **jede Anmeldung kostet einen Kopfsatz** im Flash, womöglich zusätzlich einen NVM-Schreibvorgang im Sicherheitschip. Beides ist gemeldet, nicht gerechnet.

Was in 8 MB läuft, beweist nichts für 64 MB — Adressbreite, Löschblockgröße und Verschleißverteilung ändern sich mit der Größe. (Das Entwicklungsbrett hat 8 MB, der Entwurf 64.)

Werkzeugergebnisse sind erst Belege, wenn geprüft ist, was sie messen: `pcb_layout_boxes` misst Pad-Mitten statt Kupfer, die DRC nennt je Gießflächen-Insel nur einen Vertreter, und eine Bändertabelle aus Padlagen sieht **kein Bauteil ohne Pads** — kein Anzeigenglas, keine Folie, keinen Sensor, der nur aufliegt.

---

9. Offene Punkte

Vor der Bestellung der Platinenteile:

1. **Händler-Bestellnummer des SE051C2.** Die Variante ist belegt (AN12973 Tab. 3), die Nummer für die Serie nicht. Eine Typnummer aus der Wildnis: `SE051C2HQ1/Z01XD` (`ungeprueft`, aus einer Boardbeschreibung).
2. **Flash-Rechnung.** Passen RSA, ML-KEM, age, OpenPGP, CXF, CSR und die CA-Verwaltung neben MCUboot in 1 MB? Hochrechnung heute: 264 kB von 960.
3. **Wie viele RSA-4096-Schlüssel** in den Nutzspeicher passen — hängt an Widerspruch 4.
4. **AES-256-GCM-Durchsatz am Gerät.** Liegt er unter 3 MB/s, ist er die neue Wand für den Datenträger. Nur am Gerät messbar.

4a. **Stapelbedarf des SE050-Treibers nach der erweiterten APDU-Länge.** Gefunden beim Zusammenführen von Strang A am 28.10.2026. Damit ein RSA-4096-Chiffrat (512 Byte) durchpasst, sind drei Puffer auf `SE050_MAX_PAYLOAD` = 889 Byte gewachsen: `cmd[898]` in `plain_exchange()` sowie `payload[905]` und `plain[896]` in der SCP03-Schicht. **Zusammen knapp 1,8 kB auf dem Stapel eines Fadens**, der unter Zephyr oft 1–2 kB groß ist. **Das ist kein Übersetzungsfehler und fällt am PC nicht auf** — dort ist der Stapel groß. Am Gerät ist es entweder ein Absturz oder eine Stapelwächter-Meldung. Zwei Wege: Fadenstapel vergrößern, oder die Puffer aus dem Stapel in einen festen Bereich verlegen. **Entschieden wird es an einer Messung** (`CONFIG_THREAD_ANALYZER`), nicht an einer Schätzung — und das geht erst mit dem Teststand.

Ungelöst, zwei davon dauerhaft:

5. **Gespiegelte Passkeys gegen FIDO-Zertifizierung** — hier schließen sich zwei Anforderungen aus.
6. **Fünf USB-Schnittstellen gleichzeitig** — nie an echten Rechnern geprüft, manche BIOSe stolpern darüber. Gegenmittel: einzeln abschaltbar.
7. **Untergeschobene Firmware** — dagegen hilft nur der signierte Bootloader.

8. **Mehrere Profile sind in FIDO nicht vorgesehen** — beim Profilwechsel muss man sich bei den Diensten neu anmelden.
9. **Hauptkennwort vergessen und beide Sticks verloren = alles verloren.** Deshalb ist der Notfallzettel im Einrichtungsassistenten nicht überspringbar.
10. **Lizenz** (Software und Hardware getrennt), **USB-Kennung** über pid.codes, **AAGUID** eintragen.
11. **Tasterzahl für die PIN-Eingabe am Gerät** — einer ist zäh, zwei brauchen Platz.

Wo die Einzelheiten stehen — dieser Plan wiederholt sie nicht, sonst entstehen wieder zwei Wahrheiten:

Thema	Datei im Repo
Was zum Anfangen zu bestellen ist, nach Dringlichkeit	`docs/bestellliste-teststand.md`
Datenträger: Betriebsarten, Merkle-Baum, Kartenwort	`docs/datentraeger-konzept.md`
Durchsatz, Engstellen, Chipalternativen	`docs/rechenkern-durchsatz.md`
Stromaufnahmen mit Datenblattstellen	`docs/stromaufnahme.md`
FIPS 140-3: elf Bereiche als Bauliste, 21 Bauaufgaben	`D:\claude\side-session-notes\fips-140-3.md`
Maße, Bänder, Platzierung	`hardware/layout-notes.md`

Zum Aufräumen im Repo:

Erledigt am 27.10.2026: `docs/energiebudget.md` gelöscht (der einzige Chipwert daraus, 3,00 µA Deep Power-down, steht in `docs/stromaufnahme.md`) · `hardware/layout-notes.md` und `docs/fingerprint.md` berichtigt · Gegenprobe über das ganze Repo gelaufen.

Der Befund der Gegenprobe war größer als erwartet. Die Höhengrenze ist **von 3,8 auf 2,90 mm gefallen** — ohne Akku ist der **USB-Stecker J1 das dickste Teil**. Das ist eine Verschärfung, keine Entlastung, und der Sensor der Stufe 2 (FPC2534, 2,8 mm beim BM-Lite) passt nur noch mit **0,1 mm Luft** darunter.

Was daraus offen bleibt:

12. **Das Gehäuse muss neu gezeichnet werden, nicht ausgebessert.** `cad/masse.md`, `cad/gehaeuse.md` und `cad/tools/geometry.py` hängen alle drei am Zellenraum, der mit 4,05 mm das dickste Element jeder Lagensumme war — über zwanzig Stellen, die Aufteilung quer eingeschlossen. **Alle drei sind als überholt gekennzeichnet; keine Zahl daraus gilt.** Arbeit für den Gehäuse-Strang, und sie beginnt erst, wenn das Platinenmaß steht.
13. **Bauhöhe des FPC2534 mit Fassung** — 0,83 mm ist der Sensorkörper allein. Erst mit ZIF-Steckverbinder gemessen sagt die Zahl, ob Stufe 2 ohne Gehäuseänderung geht. **Nur messbar, nicht ableitbar.**
14. `status.battery` **ist ein toter Zustand in der Firmware** — „Akku schwach" steht in fünf Sprachdateien, die Oberfläche bildet ihn auf Bernstein ab, drei Prüfungen prüfen ihn, **und nichts setzt ihn je.** Herausnehmen verschiebt die Zeichenketten-Indizes, darum gehört es dem UI-Strang und nicht dem Aufräumen. *(Dasselbe Muster wie immer: eine Entscheidung vermehrt sich in fünf Sprachen.)*

---

10. Arbeitsweise

Repo: `Z:\GitHub\opensecurekey`, öffentlich, MIT, nach `claude-md\repo.md`. README englisch, Autor „Sorglos Thomas Weirich", vierstellige Version je Teilprogramm, Oberflächen in fünf Sprachen.

```
apps/firmware/   Zephyr · src/classes/{se050,ctap,applets,transport,store,ui,wallet}
apps/desktop/    Go, lokale Weboberfläche, `osk`
apps/web/        Browser-Erweiterung
shared/          Protokoll, Tresor-Datenformat, osk-guard
hardware/        Schaltplan, Layout, Gerber, Stückliste
cad/             Gehäuse (Fusion 360)
docs/            Architektur, Bedrohungsmodell, Messprotokolle, Handbuch
tools/           build.py, set_version.py, flash.py, release.py, md2pdf.py
```

Diese Sitzung bleibt Master: verteilt, sammelt, führt zusammen, fragt als Einzige. Jeder Strang bekommt einen eigenen Zweig und fasst nur seine Ordner an.

Regeln, die aus Fehlern dieses Projekts stammen:

- **Eine Zahl nur an einer Stelle.** Maße stehen in `hardware/`, alles andere verweist. Kopien veralten still — hier fünfmal passiert, einmal quer durch das Handbuch in fünf Sprachen.
- **Befund und Begründung trennen.** Fällt die Begründung, fällt der Befund nicht mit.
- **Nicht nach der erwarteten Zahl suchen** — das findet nur den vermuteten Fehler. Alle Maßzahlen auflisten und einzeln ansehen.
- **Geteilter Checkout:** HEAD vor jedem Commit prüfen, `git add` und `git commit --` zusammen, Zweig beim Push ausdrücklich nennen.
- **Ein Werkzeugergebnis ist erst ein Beleg, wenn geprüft ist, was es misst.**
- **Was nicht am Gerät lief, wird nicht als geprüft gemeldet.**

Dieser Plan liegt zweimal — unter `.claude\plans\` (Arbeitsfassung) und als `docs/plan.md` im Repo. **Jede Änderung endet mit zwei Schritten, die zusammengehören:** Kopie ins Repo ziehen und das PDF neu erzeugen (`tools/md2pdf.py`). Sonst entstehen zwei Wahrheiten — genau das ist am 27.10. passiert und hat den Autor dieses Plans als Ersten erwischt.